

DEFENSIEVE SECURITY-AUDIT - SAFE MODE

Softora Securityrapport

Technische applicatie-, Supabase-, auth-, AI-, mailbox-, privacy- en infrastructuurreview met concrete fixroadmap.

Datum	11 mei 2026
Project	Softora - https://www.softora.nl
Scope	Eigen domein, codebase, infrastructuur en integraties
Werkmodus	SAFE MODE: lezen, rapporteren, geen fixes uitgevoerd
Security-score	61/100

Softora Securityrapport

Datum: 11 mei 2026

Project: Softora

Scope: eigen domein, eigen codebase, eigen infrastructuur, eigen integraties

Werkmodus: SAFE MODE - alleen lezen, inventariseren en rapporteren

Uitvoering: geen codewijzigingen, geen databasewijzigingen, geen productie-instellingen aangepast

1. Executive Summary

Algemene security-score: 61/100.

Softora heeft al een aantal goede basismaatregelen: premium API-routes worden achter authenticatie gezet, sessiecookies zijn HttpOnly/SameSite en in productie Secure, er is basis-rate-limiting, same-origin bescherming voor state-changing API requests, mailboxroutes zijn admin-only, Supabase storage bucket voor designfoto's is private en beperkt op MIME type en grootte, en Retell/Twilio webhooks hebben verificatiechecks.

De belangrijkste risico's zitten niet in een enkele duidelijke "alles staat open"-fout, maar in een combinatie van brede server/service-role toegang, gevoelige UI-state, veel gevoelige bedrijfsdata in runtime/backups/logs, AI/mailbox-datastromen en security headers die live niet overal consequent staan.

Top 10 belangrijkste verbeteringen:

1. Los eerst de huidige kwaliteitsblokkade op: `premium-website.html` groeit met +4 regels en blokkeert `verify:critical`.
2. Roteer kritieke keys handmatig en bevestig dat service-role keys nergens in frontend/build/logs staan.
3. Maak gevoelige UI-state scopes expliciet admin-only.
4. Ontwerp Supabase RLS per tabel op basis van echte tenant/user/company isolatie.
5. Minimaliseer runtime-backups en logs zodat telefoon, e-mail, transcript en recording URL niet volledig worden bewaard waar dat niet nodig is.
6. Beperk boekhoudbestanden: niet als DataURL in UI-state bewaren; gebruik private storage met autorisatie.
7. Zet security headers consequent op root, publieke pagina's, premium pagina's en API's.
8. Maak route-specifieke rate limits voor login, formulieren, mailbox send, AI en webhooks.
9. Voeg AI-guardrails toe tegen prompt injection en datalekken uit e-mail/transcripts.
10. Leg privacy/GDPR concreet vast: verwerkers, AI-verwerking, bewaartermijnen, exports en verwijdering.

Directe quick wins:

- Guardrail-blokkade oplossen.
- SPF DNS-record bevestigen of toevoegen.
- Root/public security headers gelijk trekken met API/premium login.

- Cookies met UI voorkeuren voorzien van `Secure` in productie.
- Logmasking invoeren voor telefoon, e-mail, transcript, recording URL en tokens.
- Sensitive UI-state scopes uitbreiden.

Grootste datalekrisico's:

- Klantdata en leaddata in brede UI-state of runtime snapshots.
- Call transcripts en recording URLs in runtime backups.
- Boekhoudbestanden als DataURL in UI-state.
- AI-verwerking van transcripts/contactdata zonder harde dataminimalisatie.

Grootste Supabase/auth-risico's:

- Server/service-role is het primaire model; dat is verdedigbaar, maar maakt server-side autorisatie extra kritiek.
- RLS is aanwezig in SQL, maar policies zijn vooral service-role gericht.
- Data-isolatie tussen gebruikers/klanten is nog niet live bewezen met twee testaccounts.

Grootste AI/e-mail-risico's:

- AI ontvangt contactdata, transcript snippets en soms volledige transcripts.
- Mailbox toont gevoelige e-maildata; rendering is escaped, maar attachment/link safety en AI-contextisolatie moeten strakker.
- Coldmail/mailbox send flows moeten streng rate-limited en auditbaar blijven.

2. Scope, Methode En Bewijsniveau

Gebruikte kaders:

- OWASP ASVS-achtige controle op authenticatie, autorisatie, input/output, sessies en logging.
- OWASP WSTG-achtige route-, endpoint- en datastroominventarisatie.
- OWASP Top 10 als risicolens.
- Supabase securityprincipes: service-role nooit in frontend, RLS op exposed schemas, policies per toegangspad, storage private waar data gevoelig is.
- Zero Trust: elke route, actie en databasehandeling apart autoriseren.
- NIST CSF-achtige indeling: Govern, Identify, Protect, Detect, Respond, Recover.

Bewijslabels:

- BEVESTIGD: direct bewijs in code, config, route, SQL of passieve live-check.
- WAARSCHIJNLIJK: sterke aanwijzing, maar live/runtime verificatie nodig.
- MOGELIJK: theoretisch risico dat door ontwerp of context kan spelen.
- NIET GENOEG BEWIJS: observatie of controlepunt, niet meetellen als echte kwetsbaarheid.

Niet uitgevoerd:

- Geen brute force.
- Geen credential stuffing.
- Geen database writes.
- Geen productieconfig aangepast.
- Geen datadumps.
- Geen destructieve checks.
- Geen volledige secrets getoond.

3. Applicatiekaart

Publieke pagina's volgens code:

Route/pagina	Status	Bewijs
/	publiek	server/routes/public-pages.js
premium-website.html	publiek	server/config/premium-public-html-files.js:6
premium-personeel-login.html	publiek/login	server/config/premium-public-html-files.js:7
premium-bedrijfssoftware.html	publiek	server/config/premium-public-html-files.js:8
premium-voicesoftware.html	publiek	server/config/premium-public-html-files.js:9
premium-chatbot.html	publiek	server/config/premium-public-html-files.js:10
premium-websites.html	publiek	server/config/premium-public-html-files.js:11
premium-blog.html	publiek	server/config/premium-public-html-files.js:12
premium-algemene-voorwaarden.html	publiek	server/config/premium-public-html-files.js:13
premium-privacy-policy.html	publiek	server/config/premium-public-html-files.js:14
premium-over-softora.html	publiek	server/config/premium-public-html-files.js:15
premium-pakketten.html	publiek	server/config/premium-public-html-files.js:16
premium-seo.html	publiek volgens configuratie	server/config/premium-public-html-files.js:17
premium-bevestigingsmails.html	publiek volgens configuratie	server/config/premium-public-html-files.js:18

Route/pagina	Status	Bewijs
premium-websitegenerator.html	publiek volgens configuratie	server/config/premium-public-html-files.js:19

Admin-achtige pagina's volgens code:

Pagina	Status	Bewijs
premium-instellingen.html	admin	server/config/premium-admin-html-files.js
premium-wachtwoordenregister.html	admin	server/config/premium-admin-html-files.js

Businesskritische premium pagina's uit scope:

Pagina	Functie	Data
/premium-database	klanten/leads/database, CSV/export, websitepreview/photo jobs	klantdata, contactdata, website/foto metadata
/premium-mailbox	mailbox lezen/verzenden	e-mailaccounts, e-mailinhoud, ontvangers
/premium-website	publieke site/homepage	marketing, cookies
/premium-vaste-lasten	terugkerende kosten	kosten/boekhoudachtige bedrijfsdata
/premium-pakketten	pakketten/aanbod	publieke content
/premium-personeel-agenda	afspraken, calls, post-call acties	afspraken, klantdata, transcript/audio
/premium-websitegenerator	website previews/library/batches	prompts, previews, website links
/premium-actieve-opdrachten	actieve orders/projecten	klant/project/orderdata, factuurstatus
/premium-klanten	klantbeheer	klantnamen, contact, status, verantwoordelijke
/premium-boekhouding	boekhoudlijst/bestanden	bestanden, notities, checklist per maand

4. Route Map En Endpoint Map

Belangrijke publieke/health endpoints:

- GET /
- GET /robots.txt
- GET /.well-known/security.txt
- GET /healthz
- GET /api/healthz
- GET /api/health/baseline

Auth/session endpoints:

- GET /api/auth/session
- POST /api/auth/login
- POST /api/auth/logout
- POST /api/agenda-app/login
- GET /api/auth/profile
- PATCH /api/auth/profile
- Admin userbeheer: /api/premium-users, /api/premium-users/:id, /api/premium-users/verify-pin

Runtime/UI-state endpoints:

- GET /api/ui-state/:scope
- GET /api/ui-state-get
- POST /api/ui-state/:scope
- POST /api/ui-state-set
- GET/POST /api/dashboard/activity
- Debug/admin runtime: /api/security/audit-log, /api/data-health, /api/runtime-sync-now, /api/runtime-backup

Mailbox/coldmail endpoints:

- GET /api/mailbox/accounts
- GET /api/mailbox/messages
- POST /api/mailbox/send
- GET /api/coldmailing/mailbox-options
- GET /api/coldmailing/campaigns/recipients
- POST /api/coldmailing/campaigns/send
- GET /api/coldmailing/replies/follow-ups
- POST /api/coldmailing/replies/sync

Agenda/coldcalling/AI endpoints:

- /api/agenda/appointments
- /api/agenda/appointments/manual
- /api/agenda/confirmation-tasks
- /api/agenda/interested-leads
- /api/coldcalling/start
- /api/coldcalling/status
- /api/coldcalling/call-updates
- /api/coldcalling/call-detail
- /api/coldcalling/recording-proxy

- `/api/ai/call-insights`
- `/api/ai/ruben-chat`
- `/api/ai/dashboard-chat`
- `/api/ai/summarize`
- `/api/ai/order-dossier`
- `/api/ai/transcript-to-prompt`
- `/api/ai/notes-image-to-text`
- `/api/ai/notes-audio-to-text`

Webhooks:

- `GET/POST /api/twilio/voice`
- `POST /api/twilio/status`
- `POST /api/retell/webhook`

Website/database endpoints:

- `/api/website-preview/generate`
- `/api/website-preview/batch`
- `/api/website-preview-library`
- `/api/website-links`
- `/api/active-orders/generate-site`
- `/api/active-orders/launch-site`
- `/api/premium-database/import-spreadsheet`
- `/api/premium-database/sync-spreadsheet`
- `/api/premium-database/add-real-businesses`
- `/api/premium-database/deep-search-businesses`
- `/api/premium-database/webdesign-photo-jobs`

5. Attack Surface Map

Inputpunten:

- Loginformulieren.
- Premium UI-state formulieren.
- Klant/leads database import en zoekfuncties.
- Agenda en afspraakformulieren.
- Mailbox send/reply flows.
- Coldmail/coldcalling start flows.
- AI prompt/transcript/image/audio endpoints.
- Websitegenerator prompts en preview library.

- Webhooks van Twilio en Retell.
- Uploads/foto's/bestanden.

Datawijzigingspunten:

- `POST /api/ui-state-set` en `POST /api/ui-state/:scope`.
- Agenda post/manual/set-in-agenda/dismiss/mark-sent acties.
- Mailbox send.
- Coldmail send/sync.
- Active order generate/launch.
- Database import/sync/deep-search/webdesign jobs.
- Premium user create/update/delete.

Gevoelige datapunten:

- Klantdata: naam, bedrijf, contact, telefoon, e-mail.
- Leads en coldcalling status.
- Transcripts, summaries en recording URLs.
- Afspraken en bevestigingstaken.
- E-mails en mailboxmetadata.
- Boekhouding en factuurstatus.
- Website/order prompts.
- Runtime audit events en backups.

Externe systemen:

- Supabase database en storage.
- OpenAI.
- Anthropic of AI-dienst in order dossier flow.
- Retell.
- Twilio.
- Mailserver/IMAP/SMTP.
- Vercel/hosting.
- DNS/e-mail: MX via `smtp.rzone.de`, DKIM aanwezig, DMARC reject, SPF niet passief bevestigd.

6. Data Flow Map

Kernstroom:

1. Gebruiker opent publieke of premium pagina.
2. Browser doet API-calls naar `/api/*`.
3. Server checkt premium/auth/admin waar route achter middleware valt.

4. Server leest/schrijft runtime state, Supabase tabellen, Supabase storage of externe API.
5. Browser rendert data in premium UI.
6. AI/mail/call flows sturen beperkte of brede context naar externe providers.
7. Runtime backups/logs bewaren onderdelen van bedrijfs- en klantdata.

Trust boundaries:

- Browser naar server: nooit vertrouwen op client-side checks.
- Server naar Supabase service-role: server moet alle autorisatie afdwingen.
- Server naar AI/mail/Retell/Twilio: dataminimalisatie en audit noodzakelijk.
- Webhook naar server: signature/secret checks noodzakelijk.
- Preview/staging naar productie: geen productiedata in preview.
- Logs/backups: behandelen als gevoelige data.

7. Businesskritische Pagina Review

Pagina	Data haalt op	Data wijzigt	Belangrijkste risico	Status
/premium-database	UI-state, customers, design photos, website jobs	import/sync/photo jobs, CSV/export	klantdata, IDOR, exportlek	WAARSCHIJNLIJK
/premium-mailbox	mailbox accounts/messages	send/reply/delete UI-acties	e-maildata, HTML/link/attachment safety	BEVESTIGD deels
/premium-website	publieke content/cookie consent	cookie voorkeur	headers/cookie Secure	BEVESTIGD laag
/premium-vaste-lasten	UI-state costs	terugkerende kosten	financiele data in UI-state	WAARSCHIJNLIJK
/premium-pakketten	publieke content	geen kritieke writes gevonden	lage securityimpact	MOGELIJK
/premium-personeel-agenda	afspraken, confirmation tasks, leads, recordings	afspraken/post-call/active order	IDOR op IDs, transcript/audio	WAARSCHIJNLIJK
/premium-websitegenerator	library, batches, links	previews, links, batches	public configuratie moet businessmatig bevestigd	WAARSCHIJNLIJK
/premium-actieve-opdrachten	orders, afspraken, UI-state	generate/launch/delete/status	orderdata, factuurstatus, launch-acties	WAARSCHIJNLIJK
/premium-klanten	klanten UI-state	klantmutaties	klantdata-isolatie, export	WAARSCHIJNLIJK
/premium-boekhouding	UI-state bookkeeping	bestanden/notities/cheeklists	bestanden als DataURL in UI-state	BEVESTIGD

Verplichte test per pagina:

- Zonder sessie directe URL openen.
- Met gewone premium gebruiker openen.

- Met admin openen.
- IDs in URL/API-call handmatig wijzigen met testdata.
- Console en network responses controleren op teveel data.
- Mutatieknoppen testen op server-side autorisatie.
- Rollback testen door oude state/config terug te zetten.

8. Threat Model Coverage Matrix

#	Risico	Waar in Softora	Status
1	Ongeautoriseerde toegang	premium routes/API	WAARSCHIJNLIJK
2	Privilege escalation	premium/admin scopes/users	WAARSCHIJNLIJK
3	Exposed admin/interne pagina's	public premium config	WAARSCHIJNLIJK
4	Direct URL access	premium HTML/API	WAARSCHIJNLIJK
5	Client-side-only beveiliging	UI-state en premium browserlogica	MOGELIJK
6	Broken access control	scopes, IDs, service-role server model	WAARSCHIJNLIJK
7	IDOR via IDs	customer/lead/appointment/order IDs	WAARSCHIJNLIJK
8	Supabase RLS bypass	service-role server model	MOGELIJK
9	Tabellen zonder RLS	data-ops SQL zet RLS aan	NIET GENOEG BEWIJS voor ontbrekend RLS
10	Policies te breed	service-role all policies	BEVESTIGD
11	Policies zonder tenant checks	huidige policies zijn service-role gericht	WAARSCHIJNLIJK
12	Public storage bucket	design bucket private	NIET GENOEG BEWIJS voor public leak
13	Service-role key leakage	niet gevonden in frontend, wel kritisch te controleren	NIET GENOEG BEWIJS
14	Anon key misuse	Supabase clientgebruik controleren	MOGELIJK
15	Gevoelige data in frontend	klant/mail/call data in browser	BEVESTIGD
16	Gevoelige data in browser storage	sessionStorage profile/sidebar	BEVESTIGD laag/medium
17	Gevoelige data in cookies	UI cookies zonder Secure	BEVESTIGD laag
18	Hardcoded secrets	geen volledige secret gerapporteerd	NIET GENOEG BEWIJS
19	Secrets in frontend bundle	moet in buildscan worden getest	NIET GENOEG BEWIJS
20	Secrets in logs	logmasking nodig	WAARSCHIJNLIJK
21	Secrets in sourcemaps	productieconfig niet volledig bewezen	NIET GENOEG BEWIJS
22	XSS	veel innerHTML, meestal escaping nodig	WAARSCHIJNLIJK
23	CSRF	same-origin guard aanwezig	MOGELIJK residu

#	Risico	Waar in Softora	Status
2 4	SQL injection/query misuse	Supabase client queries, geen SQL concat bewezen	NIET GENOEG BEWIJS
2 5	Inputvalidatie onvoldoende	agenda/import/AI/mail endpoints	WAARSCHIJNLIJK
2 6	Output escaping onvoldoende	mailbox escaped, andere innerHTML sinks testen	WAARSCHIJNLIJK
27	Onveilige HTML-rendering	blog/notepad/word/mail renderpaden	WAARSCHIJNLIJK
2 8	innerHTML/dangerous rendering	breed aanwezig	BEVESTIGD
2 9	Onveilige redirects	niet bevestigd	NIET GENOEG BEWIJS
3 0	CORS misconfiguratie	root had <code>access-control-allow-origin: *</code>	BEVESTIGD
31	Ontbrekende rate limiting	algemene/login aanwezig, route-specifiek nodig	WAARSCHIJNLIJK
3 2	Bot/spam	formulieren/coldmail/login	WAARSCHIJNLIJK
3 3	Login/session zwaktes	sessiecookies positief, MFA ontbreekt als beleid	MOGELIJK
3 4	Onveilige e-mailflows	mailbox/coldmail send	WAARSCHIJNLIJK
3 5	E-mail injection	send flows moeten header/body validatie bewijzen	MOGELIJK
3 6	Onveilige e-mail HTML	mailbox body escaped	MOGELIJK residu
37	Attachment risico's	attachment safety niet bewezen	WAARSCHIJNLIJK
3 8	SPF/DKIM/DMARC	DMARC/DKIM positief, SPF niet gevonden	WAARSCHIJNLIJK
3 9	AI prompt injection	AI krijgt user/transcript input	WAARSCHIJNLIJK
4 0	AI data leakage	transcript/contact naar AI	BEVESTIGD
41	AI tool/action misuse	AI endpoints/action flows	MOGELIJK
4 2	AI mailbox/context leakage	AI en mail naast elkaar in premium context	MOGELIJK
4 3	Logging gevoelige data	lead trace/runtime audit/backups	WAARSCHIJNLIJK
4 4	Onveilige error messages	console/server errors controleren	MOGELIJK
4 5	Stack traces	server error route controleren	MOGELIJK

#	Risico	Waar in Softora	Status
4 6	Security headers ontbreken	root passieve check incompleet	BEVESTIGD
47	Clickjacking	API/premium helmet positief, root check nodig	WAARSCHIJNLIJK
4 8	MIME sniffing	root check mist nosniff	BEVESTIGD
4 9	Referrer leakage	helmet referrer positief op API/premium	MOGELIJK root residu
5 0	Dependency vulnerabilities	<code>npm audit --omit=dev</code> eerder 0	NIET GENOEG BEWIJS actueel
51	Supply-chain	geen lock/CI maturity volledig beoordeeld	MOGELIJK
5 2	Third-party scripts	cdnjs/fonts/AI providers	MOGELIJK
5 3	Backups/recovery	backups bestaan, restore test niet bewezen	WAARSCHIJNLIJK
5 4	Monitoring	audit events aanwezig, alerting onbekend	WAARSCHIJNLIJK
5 5	Audit logging	aanwezig maar PII/retention risico	WAARSCHIJNLIJK
5 6	Klantdata-scheiding	server/service-role en UI-state	WAARSCHIJNLIJK
57	Privacy/GDPR	privacytekst generiek/placeholder KVK	BEVESTIGD
5 8	Deployment instellingen	Vercel/root headers/preview onbekend	WAARSCHIJNLIJK
5 9	Preview deployments	niet live bewezen	NIET GENOEG BEWIJS
6 0	DNS/e-mail spoofing	SPF niet passief bevestigd	WAARSCHIJNLIJK
61	Webhook misbruik	signature checks positief	MOGELIJK residu
6 2	Open endpoints zonder auth	public API allowlist en webhooks	WAARSCHIJNLIJK te reviewen
6 3	Source maps/build artifacts	niet getest in productie	NIET GENOEG BEWIJS
6 4	Test/demo credentials	geen volledig bewijs	NIET GENOEG BEWIJS
6 5	Least privilege	service-role breed	BEVESTIGD
6 6	Secret rotation	beleid niet bewezen	WAARSCHIJNLIJK
67	Incident response	plan niet bewezen	WAARSCHIJNLIJK
6 8	Rollback strategie	docs aanwezig, restore test nodig	WAARSCHIJNLIJK

#	Risico	Waar in Softora	Status
69	Staging/productie scheiding	niet bewezen	NIET GENOEG BEWIJS
70	Access review/MFA	niet bewezen	WAARSCHIJNLIJK

9. Findings

Critical

Geen bevestigde Critical findings gevonden in SAFE MODE.

High Findings

H-01 - Gevoelige UI-state scopes zijn niet breed admin-only

Ernst: High

Status: BEVESTIGD

Kans: hoog

Impact: hoog

Bewijs: `server/config/admin-ui-state-scopes.js:5-7` bevat alleen `premium_password_register`.

Betrokken bestanden: `server/config/admin-ui-state-scopes.js`, `server/routes/runtime-ops.js`, premium UI-state clients.

Betrokken pagina's/routes: premium database, klanten, boekhouding, vaste lasten, actieve opdrachten, agenda, dashboard.

Betrokken endpoints: `/api/ui-state/:scope`, `/api/ui-state-get`, `/api/ui-state-set`.

Betrokken data: klantdata, boekhouding, kosten, notities, operationele state.

Oorzaak: gevoelige scopes worden niet expliciet als admin-only geclassificeerd.

Impactscenario: een premium gebruiker met te brede rechten kan gevoelige state lezen of wijzigen als de scope niet apart beschermd is.

Veilige fix: voeg een allowlist toe van gevoelige scopes die altijd admin-only zijn, met tests per scope.

Regressierisico: te strenge scope kan legitieme premium pagina's data ontnemen.

Testplan: gewone premium gebruiker en admin vergelijken; directe API-call per scope testen.

Rollbackplan: scope tijdelijk terughalen uit admin-only lijst.

H-02 - Supabase toegang is sterk afhankelijk van service-role serverpad

Ernst: High

Status: BEVESTIGD

Kans: medium

Impact: hoog

Bewijs: `supabase/production-hardening.sql:20-27` geeft `service_role` brede tabelrechten; `:52` maakt policies met `using (true)` en `with check (true)` voor `service_role`.

Betrokken bestanden: `supabase/production-hardening.sql`, Supabase repositories/services.

Betrokken data: runtime state, customers, active orders, order runtime, design photos, webdesign jobs.

Oorzaak: security wordt vooral door serverroutes gedragen; RLS is niet de primaire tenant-isolatielaag.

Impactscenario: als server-side autorisatie ergens tekortschiet, kan service-role pad te veel data

bereiken.

Veilige fix: server-side auth behouden, maar RLS/policies per tenant/user/company ontwerpen als defense in depth.

Regressierisico: te strakke policies breken legitieme serverflows.

Testplan: twee testgebruikers, aparte testrecords, select/insert/update/delete per rol controleren.

Rollbackplan: migration met vorige policies terugzetten.

H-03 - Boekhoudbestanden worden als DataURL in UI-state bewaard

Ernst: High

Status: BEVESTIGD

Kans: hoog

Impact: hoog

Bewijs: `assets/premium-bookkeeping.js:6` gebruikt scope `premium_bookkeeping`; :341-350 leest bestanden met `FileReader` als DataURL en slaat die op in state.

Betrokken pagina: `/premium-boekhouding`.

Betrokken data: boekhoudbestanden, mogelijk facturen of administratieve bijlagen.

Oorzaak: bestanden worden in algemene UI-state verwerkt in plaats van private storage met object-level autorisatie.

Impactscenario: iedereen met toegang tot die scope kan volledige bestandsinhoud ontvangen.

Veilige fix: bestanden opslaan in private Supabase Storage bucket met signed URLs, MIME/size checks en autorisatie per object.

Regressierisico: bestaande bestanden moeten gemigreerd of tijdelijk compatibel gehouden worden.

Testplan: upload/download/delete met admin en onbevoegde testgebruiker.

Rollbackplan: compat-leespad tijdelijk behouden, writes terug naar oude methode alleen als noodmaatregel.

H-04 - Runtime backups bevatten gevoelige klant/call/agenda data

Ernst: High

Status: BEVESTIGD

Kans: medium

Impact: hoog

Bewijs: `server/services/runtime-backup.js:102-128` bevat telefoon, naam, transcript en recording URL; :262-285 bevat agenda contact, telefoon, summary en callId.

Betrokken data: telefoon, naam, transcript, recording URL, afspraken, call details.

Oorzaak: backups bewaren brede operationele snapshots.

Impactscenario: toegang tot backup/logbestand geeft veel gevoelige bedrijfs- en klantcontext.

Veilige fix: backup payload minimaliseren en gevoelige velden maskeren of apart versleuteld bewaren.

Regressierisico: debugging/herstel wordt minder rijk.

Testplan: runtime backup maken met testdata en controleren dat PII gemaskeerd of uitgesloten is.

Rollbackplan: vorige backup serializer tijdelijk terugzetten.

H-05 - Delete/retention is soft-delete of onvolledig bewezen

Ernst: High

Status: BEVESTIGD voor design photos soft-delete

Kans: medium

Impact: hoog

Bewijs: `server/services/data-ops-store.js:480-490` zet `deleted_at`, maar verwijdert storage object

niet direct in dit pad.

Betrokken data: design photos en mogelijk klantbestanden.

Oorzaak: verwijdering markeert records als verwijderd, maar fysieke object-retentie is niet volledig geregeld.

Impactscenario: bestanden blijven bestaan na delete/privacyverzoek.

Veilige fix: lifecycle/retention job en expliciete storage delete toevoegen waar juridisch/operationeel nodig.

Regressierisico: herstel van per ongeluk verwijderde bestanden wordt lastiger.

Testplan: testobject uploaden, verwijderen, directe objecttoegang controleren.

Rollbackplan: soft-delete blijven gebruiken, hard-delete job pauzeren.

H-06 - Security headers live niet overal consequent

Ernst: High

Status: BEVESTIGD via passieve live-check

Kans: medium

Impact: hoog

Bewijs: root `https://www.softora.nl` gaf HSTS, maar geen volledige CSP/X-Frame-Options/nosniff; API en `/premium-personeel-login` hadden wel Helmet headers.

Betrokken routes: `/`, publieke HTML, premium HTML, `/api/*`.

Oorzaak: headerconfig wordt niet gelijk toegepast op alle responses/deploymentpaden.

Impactscenario: root/publieke routes missen browserbescherming tegen clickjacking, MIME sniffing en script-injectierisico's.

Veilige fix: security headers centraal afdwingen via server/hosting config.

Regressierisico: CSP kan inline scripts of externe assets blokkeren.

Testplan: headers controleren op root, publieke pagina, premium pagina en API.

Rollbackplan: CSP eerst Report-Only of gefaseerd terugzetten.

Medium Findings

M-01 - Sommige premium-pagina's staan bewust of onbewust publiek

Status: WAARSCHIJNLIJK

Bewijs: `server/config/premium-public-html-files.js:5-20` bevat onder andere `premium-bevestigingsmails.html`, `premium-websitenerator.html` en `premium-seo.html`.

Risico: interne functies kunnen publiek bereikbaar zijn als dit niet bewust bedoeld is.

Fix: per pagina labelen als publiek, login-only, premium-only of admin-only.

M-02 - AI ontvangt klant/call/transcript data

Status: BEVESTIGD

Bewijs: `server/services/ai-call-insights.js:674-708` stuurt call metadata en transcript naar OpenAI; `server/services/order-dossier.js:473-490` stuurt klantomschrijving/transcript naar AI-prompt.

Risico: datalek via AI-provider, prompt injection of teveel context.

Fix: dataminimalisatie, consent/beleid, prompt-injection guardrails, audit zonder inhoud.

M-03 - Logs en traces kunnen PII bevatten

Status: WAARSCHIJNLIJK

Bewijs: `server/services/lead-trace.js:80` logt payloads; runtime events slaan

email/IP/path/origin/detail/userAgent op.

Risico: gevoelige klantdata in logs.

Fix: masking en retention.

M-04 - Browser/session storage bevat profieldata

Status: BEVESTIGD

Bewijs: `assets/personnel-theme.js:1529` schrijft sidebar session state; `assets/premium-sidebar-profile-prefill.js:92` leest sessionStorage.

Risico: lokale browserdata bevat profiel/avatar context.

Fix: minimaliseren, TTL, geen gevoelige data in sessionStorage.

M-05 - Veel HTML rendering sinks

Status: BEVESTIGD

Bewijs: brede aanwezigheid van `innerHTML` in premium pagina's en assets; mailbox body gebruikt wel `escapeHtml`.

Risico: XSS als een sink ooit ongesanitized user input krijgt.

Fix: centrale escape/sanitize helpers, CSP aanscherpen, risky sinks per pagina reduceren.

Low Findings

L-01 - UI cookies missen Secure in sommige browserpaden

Status: BEVESTIGD

Bewijs: `premium-website.html:3558`, `premium-ai-coldmailing.html:3452`, `assets/personnel-theme.js:1247`.

Impact: laag tot medium; voorkeurcookies kunnen via niet-HTTPS context zwakker zijn.

Fix: Secure toevoegen wanneer `location.protocol === 'https:'`.

L-02 - Privacyverklaring bevat placeholder-achtig KvK-nummer

Status: BEVESTIGD

Bewijs: `premium-privacy-policy.html:172` bevat 12345678.

Impact: juridisch/vertrouwen.

Fix: echte KvK en bedrijfsgegevens invullen.

Observations

- `server/security/premium-session.js:104-110` bouwt sessiecookies met SameSite Lax en Secure in productie.
- `server/services/premium-route-runtime.js:71` zet `/api` achter premium API access middleware.
- `server/security/request-context.js:181-243` blokkeert state-changing cross-site requests via Fetch Metadata/Origin checks.
- `server/routes/mailbox.js:9-11` zet mailbox accounts/messages/send achter admin access.
- `assets/premium-mailbox.js:253` escaped e-mailbody bij weergave.
- `supabase/data-ops-schema.sql:112-124` maakt design photo bucket private met MIME/size limits.

10. Supabase Security Review

Tabeloverzicht:

Tabel	Gevoelige data	RLS status in SQL	Policy status	Risico
softora_runtime_state	brede UI/runtime state	enabled	service_role all	High
softora_customers	klant/lead PII	enabled	service_role all	High
softora_active_orders	klant/orderdata	enabled	service_role all	High
softora_order_runtime	order runtime	enabled	service_role all	Medium/High
softora_design_photos	klantfoto metadata/storage refs	enabled	service_role all	High
softora_webdesign_jobs	job prompts/status	enabled	service_role all	Medium

Bucket review:

Bucket	Public	MIME/size	Status
softora-design-photos	false	PNG/JPEG/WebP, 10MB	positief, object-level test nodig

Key review:

- Geen volledige secret getoond of gerapporteerd.
- Service-role hoort alleen server-side. Dit moet met build/bundle/log scan worden bevestigd.
- Roteer kritieke keys na audit/fixes.

Concrete policy-fixes:

1. Definieer tenant/company/user eigenaarschap per tabel.
2. Maak RLS policies per operatie: select, insert, update, delete.
3. Houd service-role alleen voor gecontroleerde serverjobs.
4. Test met twee testgebruikers en gescheiden testrecords.
5. Controleer views/functions op security-definer risico's voordat ze exposed worden.

11. Auth / Access-Control Review

Positieve controles:

- Premium session cookie is HttpOnly/SameSite/Secure in productie.
- /api wordt na auth-routes beschermd met premium middleware.
- Admin-only API helper bestaat voor gevoelige routes.
- Mailbox en premium user management gebruiken admin access.

Risico's:

- Public premium page list moet businessmatig worden gevalideerd.

- UI-state scopes zijn te beperkt geclassificeerd als admin-only.
- Server/service-role model maakt server-side autorisatie doorslaggevend.
- Directe URL en IDOR tests zijn nog nodig per businesskritische pagina.

Aanbevolen fixes:

- Per pagina routeklasse vastleggen: publiek, login-only, premium-only, admin-only.
- Per actie server-side role check afdwingen.
- Geen gevoelige businessregel alleen in frontend.
- MFA verplicht maken voor beheeraccounts.

12. API Review

Belangrijkste API-risico's:

- Brede UI-state endpoints.
- Muterende agenda/order/database endpoints met ID parameters.
- AI endpoints met transcript/audio/image input.
- Mailbox send en coldmail send als misbruikgevoelige acties.
- Webhooks als externe ingang.

Aanbevolen API hardening:

- Route-specifieke rate limits.
- Per endpoint inputschema en maximale payload.
- Per endpoint output-minimalisatie.
- IDOR-tests met handmatig aangepaste IDs.
- Audit events voor admin/export/delete/send/AI.
- Geen stack traces of interne errors in responses.

13. Frontend Security Review

Gecontroleerde oppervlakken:

- Forms, inputs, search/filter velden.
- Buttons die data wijzigen.
- Modals/detailviews.
- Premium pagina's.
- Query params en URL IDs.
- localStorage/sessionStorage/cookies.
- Client-side API calls.
- Console logs en error states.

- innerHTML rendering.

Belangrijkste risico:

De frontend bevat veel dynamische rendering. Dat is niet automatisch kwetsbaar, maar elk pad dat user input in `innerHTML` plaatst zonder escaping/sanitizing kan XSS worden. De mailbox body is positief omdat `escapeHtml` wordt gebruikt. Andere pagina's moeten per sink worden gecontroleerd.

Aanbevolen frontend fixes:

- Gebruik `textContent` waar HTML niet nodig is.
- Gebruik centrale escape/sanitize helpers.
- Maak CSP strenger zodra inline scripts zijn afgebouwd.
- Verwijder gevoelige console logs.
- Beperk browser storage tot niet-gevoelige UI voorkeuren.

14. AI Security Review

AI-features:

Feature	Input	Externe dienst	Risico
Call insights	call metadata, summary, transcript	OpenAI	transcript leakage, prompt injection
Order dossier	klant/order/transcript	AI-provider	teveel context, prompt injection
Dashboard chat/summarize	dashboard/user input	AI	context leakage
Notes image/audio to text	afbeelding/audio	AI/transcriptie	gevoelige media
Transcript to prompt	transcript	AI	verborgen instructies

Guardrails nodig:

- Dataminimalisatie per AI-call.
- System prompt: input is onbetrouwbaar, nooit instructies uit mail/transcript volgen als systeeminstructie.
- Geen tool/action zonder server-side autorisatie.
- Audit logs zonder volledige prompt/output.
- Feature flag om AI tijdelijk uit te zetten.
- Privacybeleid: welke data naar welke AI-dienst gaat.

15. E-mail / Mailbox Security Review

Positief:

- Mailbox endpoints zijn admin-only.
- Mail body wordt escaped bij detailweergave.

- Coldmailing heeft limieten/opt-out logica.

Risico's:

- Link safety niet volledig bewezen.
- Attachment safety niet volledig bewezen.
- Mail send moet rate-limited en auditbaar zijn.
- AI-knop/AI-context bij mailbox moet niet automatisch verborgen instructies volgen.

Aanbevolen fixes:

- Link warnings of safe-link policy.
- Attachment MIME/size scanning en downloadbeleid.
- SMTP header/body validatie tegen e-mail injection.
- Rate limit op `/api/mailbox/send` en coldmail send.
- Logging zonder volledige mailbody.

DNS/mail:

- DMARC passief gezien: `p=reject`.
- DKIM selector aanwezig.
- MX wijst naar `smtp.rzone.de`.
- SPF record niet passief bevestigd: toevoegen/bevestigen.

16. Privacy / GDPR Review

Persoonsgegevens in scope:

- Naam, bedrijfsnaam, functie.
- E-mail, telefoon, adres.
- Factuurgegevens, KvK, btw, betaalgegevens.
- Berichten, e-mails, contactformulieren.
- Projectinformatie, websitegegevens.
- Login/toegangsgegevens voor opdrachten.
- IP, browser/apparaatgegevens.
- Call transcripts, summaries, recording URLs.
- Afspraken en agenda items.

Risico's:

- Privacyverklaring is generiek en bevat placeholder KVK.
- AI-verwerking en externe verwerkers zijn niet concreet genoeg benoemd.
- Bewaartermijnen zijn niet per systeem technisch afgedwongen.
- Logs/backups kunnen gevoelige data bevatten.

- Exports/downloads moeten extra beschermd worden.

Aanbevolen privacy-fixes:

- Verwerkerslijst concreet maken.
- AI-verwerking expliciet beschrijven.
- Retentie per datatype technisch vastleggen.
- Export/delete procedure maken.
- Logging/backups maskeren en beperken.
- DPIA-light maken voor AI/mail/call processing.

17. Secrets / Config / Deployment Review

Secret-risico's:

- Geen volledige secret blootgelegd in dit rapport.
- Service-role en externe API keys moeten server-only blijven.
- Secrets mogen niet in tracked files, frontend bundle, logs of source maps staan.

Deployment risico's:

- Root headers verschillen van API/premium login headers.
- Preview deployments en staging/productie scheiding zijn niet bewezen.
- Branch protection en CI bestaan als projectguardrail, maar huidige lokale guardrail faalt door bestaande diff.

Aanbevolen fixes:

- Secret scanning lokaal en in CI.
- Bundle scan op private key patronen.
- Vercel/hosting env vars nalopen.
- Preview deployments zonder productiedata.
- Source maps in productie expliciet beleid geven.

18. Security Headers Advies

Aanbevolen headers:

Header	Aanbevolen waarde	Regressierisico
Content-Security-Policy	start met huidige CSP op alle routes; daarna <code>unsafe-inline</code> afbouwen	inline scripts/styles kunnen breken
Strict-Transport-Security	<code>max-age=31536000; includeSubDomains; preload</code> na bevestigde HTTPS	subdomeinen moeten HTTPS-ready zijn

Header	Aanbevolen waarde	Regressierisico
X-Frame-Options	DENY of CSP <code>frame-ancestors 'none'</code>	embeds kunnen breken
X-Content-Type-Options	<code>nosniff</code>	laag
Referrer-Policy	<code>strict-origin-when-cross-origin</code>	analytics detail kan dalen
Permissions-Policy	camera/mic/geolocation/payment/usb uit tenzij nodig	features kunnen toestemming missen
Cross-Origin-Opener-Policy	<code>same-origin</code> waar mogelijk	externe popups/integraties testen
Cross-Origin-Resource-Policy	<code>same-origin</code> waar mogelijk	externe asset flows testen

Testmethode:

- Headers controleren op `/`, publieke pagina, premium login, premium pagina en `/api/healthz`.
- CSP eerst in Report-Only bij strenge wijzigingen.
- Browserconsole controleren op geblokkeerde legitieme assets.

19. Infrastructure / Operations Review

Status:

- HTTPS/HSTS aanwezig op live root.
- Vercel zichtbaar in live headers.
- DMARC reject positief.
- DKIM aanwezig.
- SPF niet passief bevestigd.
- Monitoring/alerting, restore tests en preview scheiding niet bewezen.

Aanbevolen operations hardening:

- MFA voor hosting, Supabase, mail, GitHub en AI accounts.
- Least privilege voor alle beheeraccounts.
- Periodieke access reviews.
- Backup en restore test.
- Incident response runbook.
- Alerting op verdachte login/export/delete/admin/mail/AI-acties.
- WAF/CDN/botbescherming voor login/formulieren.
- Dependency scanning en secret scanning in CI.

20. Fixvoorstellen - Niet Uitgevoerd

Fixvolgorde:

1. Secrets/key exposure: keys roteren en scans toevoegen.
2. Auth/access control: admin-only scopes en routeklassen.
3. Supabase RLS/policies: tenant/user/company policy ontwerp.
4. API/data leakage: payloads minimaliseren.
5. XSS/input/output: HTML sinks reduceren en sanitizen.
6. Security headers/CSP: root en publieke paden gelijk trekken.
7. Rate limiting/bot protection: route-specifieke limieten.
8. AI security: dataminimalisatie en prompt-injection guardrails.
9. Mailbox/e-mail: link/attachment safety en send limits.
10. Logging/monitoring/backups: PII masking en alerts.
11. Privacy/GDPR: verwerkers, AI, retentie, exports.
12. Code cleanup: grote HTML splitsen naar assets.

Elke fix moet klein, testbaar en terugdraaibaar zijn.

21. Veilig Validatieplan

Minimale acceptatietests:

1. Publieke pagina's laden correct.
2. Premium-pagina's zijn beschermd.
3. Login/logout werkt.
4. Sessies verlopen correct.
5. Data ophalen werkt alleen voor bevoegde gebruiker.
6. Data opslaan werkt alleen met server-side checks.
7. Geen gevoelige data in browserconsole.
8. Geen secrets in frontend bundle.
9. Geen ongeautoriseerde directe URL-toegang.
10. Geen klantdata zichtbaar voor verkeerde gebruiker.
11. Supabase RLS werkt met twee testgebruikers.
12. Formulieren werken en zijn rate-limited.
13. Mailflows werken veilig met testmailbox.
14. AI lekt geen gevoelige data en volgt geen verborgen instructies.
15. Security headers staan goed.
16. Rate limits/botbescherming werken.
17. Error states lekken geen intern detail.

18. File/media toegang is object-level beschermd.
19. Storage buckets lekken geen data.
20. Rollback is mogelijk.
21. Backups/restore zijn getest of ingepland.
22. Preview/staging/productie zijn gescheiden.
23. Geen regressie op businesskritische pagina's.

Bewijs per test:

- Datum.
- Omgeving.
- Accounttype.
- Route/actie.
- Verwacht resultaat.
- Werkelijk resultaat.
- Screenshot/logregel zonder gevoelige data.
- Status: geslaagd, gefaald of blokkade.

22. Extreme Hardening Roadmap

Fase 1 - Vandaag:

- Guardrail-blokkade oplossen.
- Keys roteren en server-only bevestigen.
- Sensitive UI-state scopes admin-only maken.
- Root security headers fixen.
- SPF bevestigen/toevoegen.

Fase 2 - Deze week:

- Supabase RLS per tabel ontwerpen.
- Server-side authorization op acties aanscherpen.
- IDOR-tests met twee accounts.
- Route-specifieke rate limits.
- Logmasking.
- Mailbox link/attachment beleid.

Fase 3 - Deze maand:

- CSP strenger maken.
- Grote premium HTML-bestanden opsplitsen.
- AI guardrails.

- Backup/restore test.
- Monitoring/alerting.
- Privacyverklaring en verwerkerslijst bijwerken.

Fase 4 - Professioneel niveau:

- Zero Trust per route en actie.
- Least privilege overall.
- MFA verplicht voor beheer.
- Password manager beleid.
- Secret rotation schema.
- SAST, DAST, dependency scanning, secret scanning.
- Branch protection en PR reviews.
- Staging/productie strikt gescheiden.
- WAF/CDN/botbescherming.
- `security.txt` actueel houden.
- Periodieke access reviews.
- Jaarlijkse externe pentest.

23. Huidige Blokkade

De verplichte projectcheck `npm run verify:critical` faalt op dit moment door bestaande lokale wijzigingen die niet in deze rapportactie zijn gemaakt. De concrete blokkade:

- `premium-website.html` is een groot frontendbestand en is netto +4 regels gegroeid.
- Guardrailregel: grote frontendbestanden mogen niet verder groeien zonder opsplitsing naar `assets/*` of bewuste uitzondering.

Deze blokkade moet worden opgelost voordat codefixes betrouwbaar afgerond kunnen worden.

24. Eindcontrole

Eindcontrole status:

- Routes geïnventariseerd: ja, op basis van code.
- Premium pagina's meegenomen: ja.
- API endpoints meegenomen: ja, met focus op kritieke groepen.
- Supabase/RLS/key risico's meegenomen: ja.
- Auth/access-control meegenomen: ja.
- AI/mailbox risico's meegenomen: ja.
- Privacy/GDPR meegenomen: ja.

- Secrets/config/deployment meegenomen: ja.
- Security headers meegenomen: ja.
- Findings gelabeld met bewijsniveau: ja.
- Per finding bewijs gegeven: ja.
- Fixes voorgesteld, niet uitgevoerd: ja.
- Geen secrets volledig getoond: ja.
- Geen destructieve acties uitgevoerd: ja.

25. Aanbevolen Volgende Stap

Start met P0-fixronde 1, pas na expliciete toestemming:

1. Guardrail-blokkade rond `premium-website.html` oplossen.
2. Secrets/key scan en rotatiecheck voorbereiden.
3. Admin-only UI-state scopes uitbreiden.
4. Supabase RLS policyplan uitschrijven voor akkoord voordat databasewijzigingen worden uitgevoerd.